

Q.1 Explain the difference between authentication and authorization.

|            | Authentication                                                                                 | Authorization                                                 |
|------------|------------------------------------------------------------------------------------------------|---------------------------------------------------------------|
| Definition | Verifying a user's identity before giving them permission to access a system, account or file. | Verifying a user's access level to a system account or file.  |
| Purpose    | To Confirm the user's identity and prevent unauthorized access                                 | To Ensure users can only access resources they are allowed to |
| Process    | Compares user Credentials with stored data                                                     | Grants or denies access based on roles / permissions          |
| Methods    | Username/password, OTP, Security question                                                      | Role-Based Access Control (RBAC), Permissions                 |

Q.2 Why should passwords never be stored in plain text?

~~As~~ Passwords should never be stored in plain text because if the database is compromised, attacker can immediately read and misuse all user passwords.

The Danger of Storing passwords in plaintext

1. Easy to read.
2. Risk of Data Breaches.
3. Account Compromise.
4. Password reuse risk.
5. No Security protection.
6. Violates Security Standards.
7. Hashing is safer.

Q3 What is the purpose of password hashing?

Ans Password hashing converts a password into a fixed length encrypted hash. This helps protect passwords because the original password cannot be easily recovered from the hash.

1. Protects user passwords.
2. Prevent plain-text storage.
3. One-way process
4. Improves security.
5. Verifies login securely.
6. Reduces Risk of password theft.
7. Follows Best practices: password hashing is a standard cybersecurity practice used to secure user authentication.

Q.4 How does duplicate login prevention improve security?

Ans Duplicate login prevention allows one active session per user. it reduces the risk of unauthorized access by preventing multiple simultaneous logins using the same account.

1. prevents multiple active sessions: allows only one active login per user accounts at a time
2. Reduce Unauthorized access: stop others from using the same account simultaneously with stolen credentials.
3. protects user Data: prevents unauthorized users from viewing or modifying sensitive information.
4. prevents account sharing, and improves session management.
5. Reduces security risks: Helps prevent session hijacking and misuse of active accounts

Q.5 Suggest two additional security improvement for your application.

Ans 1. Encrypt Communication using SSL/TLS

Encrypt all data exchanged between the client and server. So username, passwords, and messages cannot be intercepted by attacker on the network.

2. Implement Two-Factor authentication (2FA).

Require users to enter a one-time verification code (OTP) after entering the correct password. Providing an additional layer of security even if a password is compromised.